

SiteLens

网站安全透视系统

验证型 Web 漏洞扫描器 · 指纹识别 → 漏洞验证 → 情报关联 全链路



汇报大纲

01

选题背景与考核目标

为什么做网站安全扫描器，对应哪些考核要求

02

系统设计与实现

四层架构 · 面向对象四大特性 · 爬虫技术 · 核心模块

03

测试与验证

49 项单测 + 32 项冒烟 + 真实站点实测

04

总结与展望

成果、不足与改进方向

选题背景与考核目标

为什么做这个系统

- ▶ 现代网站由数十种第三方组件拼装：框架、CDN、统计、支付...任一组件的历史漏洞都可能成为入侵入口
- ▶ 全球漏洞情报每天新增数十条，人工翻源码、背 CVE 的评估方式效率低、易漏判
- ▶ 信息安全专业需要一套真实可用的授权评估工具，而非演示玩具
- ▶ 选题对应考核示例四「安全扫描器（综合）」并做了深度扩展

对应课程考核要求

封装 / 继承 / 多态 / 组合

检测器继承体系 + 组合根引擎

requests 爬虫技术

会话管理 · 限速 · BeautifulSoup 解析

综合运用与扩展

PostgreSQL · 异步任务 · Web 工作台 · 导出

合法合规

SSRF 防护 · 限速 · 仅限授权目标

系统定位：一次输入，完成一次安全评估

看清

被动指纹识别

7 检测器 × 2850+ 指纹
响应头/Cookie/meta/DOM/脚本



验证

漏洞主动验证

2613 条社区模板 + 42 条无害检测
发请求证实，命中才叫已验证



定论

情报三级判定

版本区间比对 + KEV 红标
评分与中文修复建议

结果全量存入本地 PostgreSQL：可检索、可对比、可导出 —— 结论逐条附原始证据，可人工复核

2850+

产品指纹

2613

验证模板

11024

漏洞情报

1695

KEV 在野利用

49+32

项测试全过

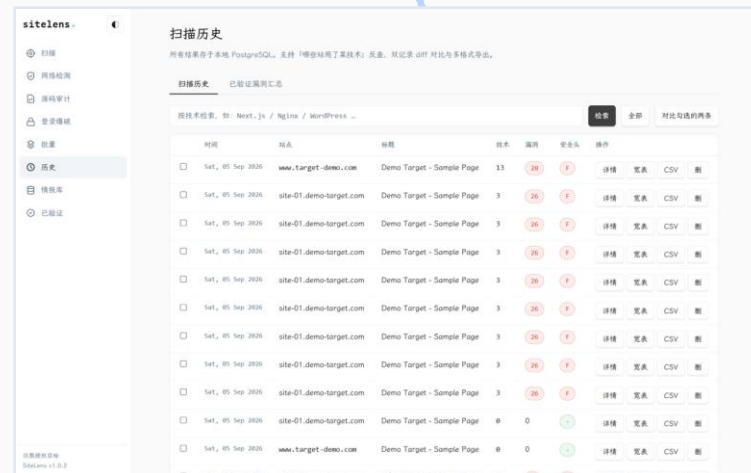
系统界面：真实运行实况



首页 · 输入入口与实时统计



扫描结果 · 技术指纹按类别分组



扫描历史 · 详情与四格式导出

现场演示路线 输入授权网址 → 深度识别 (约 15s) → 技术清单与置信度 → 已验证漏洞 → 情报三级判定 → 安全响应头评分 → 一键导出宽表 CSV。全过程数据仅存于本地 PostgreSQL。

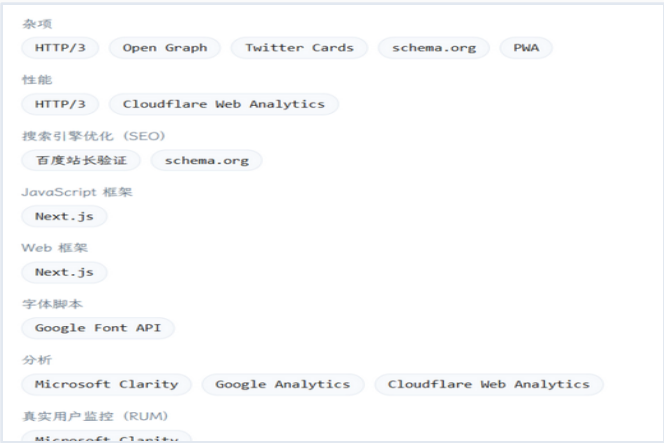
结果页细节：每条结论都能放大了看



完整扫描结果（已脱敏）

严重度	判定	涉及技术	漏洞	来源
严重		Next.js	CVE-2025-29927 Next.js Middleware鉴权绕过漏洞	afrog
严重		Next.js	CVE-2025-29927 Next.js Middleware 安全控制绕过漏洞-CVE-2025-29927	tscan
严重		Next.js	CVE-2025-55182 React Server Components 反序列化远程代码执行漏洞-CVE-2025-55182	tscan
高危		Next.js	CVE-2017-16877 Nextjs v2.4.1 LFI	afrog
高危		Next.js	CVE-2017-16877 Nextis 2.4.1 本地文件包含漏洞	tscan

漏洞情报关联：严重度徽章 · 确认受影响 CVE · 来源双源标注



严重度	判定	涉及技术	漏洞	来源
严重		Next.js	CVE-2025-29927 Next.js Middleware鉴权绕过漏洞	afrog
严重		Next.js	CVE-2025-29927 Next.js Middleware 安全控制绕过漏洞-CVE-2025-29927	tscan
严重		Next.js	CVE-2025-55182 React Server Components 反序列化远程代码执行漏洞-CVE-2025-55182	tscan
高危		Next.js	CVE-2017-16877 Nextjs v2.4.1 LFI	afrog
高危		Next.js	CVE-2017-16877 Nextis 2.4.1 本地文件包含漏洞	tscan

设计要点 结果页每个分区都可展开原始证据；情报表按严重度排序、来源双源标注；结论与证据一一对应，可逐条人工复核。

总体架构：四层设计

展示层

首页 · 扫描工作台 · 审计 · 批量 · 历史 · 情报库 · API 文档（零构建手写前端）

应用层

Flask 页面路由 · REST API（14 组） · 异步任务队列（3 并发信号量）

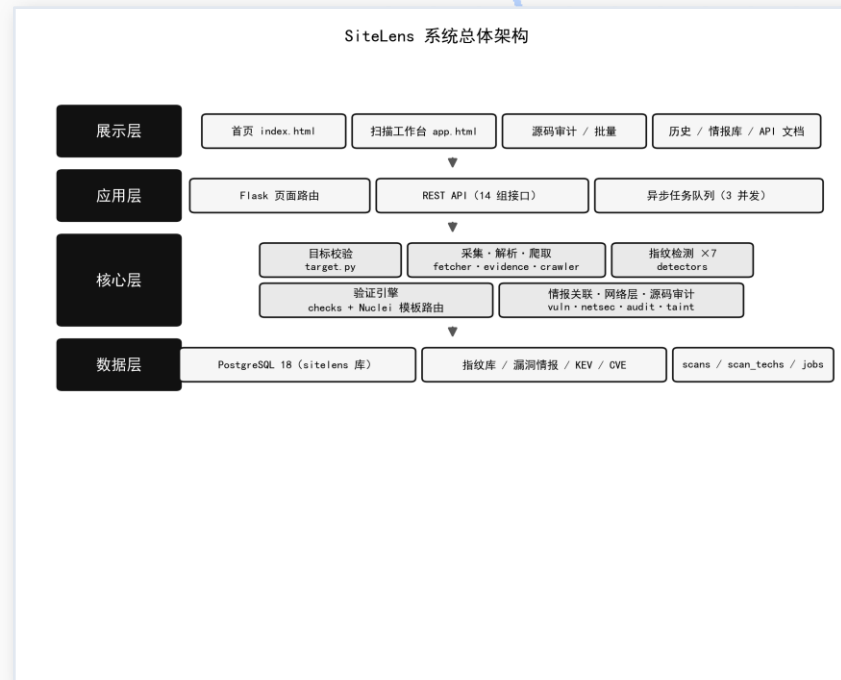
核心层

目标校验 · 采集解析 · 指纹检测 × 7 · 验证引擎 · 情报关联 · 网络层 · 审计 · 爆破

数据层

PostgreSQL 18: 指纹库 / 漏洞情报 / KEV / CVE / 扫描结果 / 任务队列

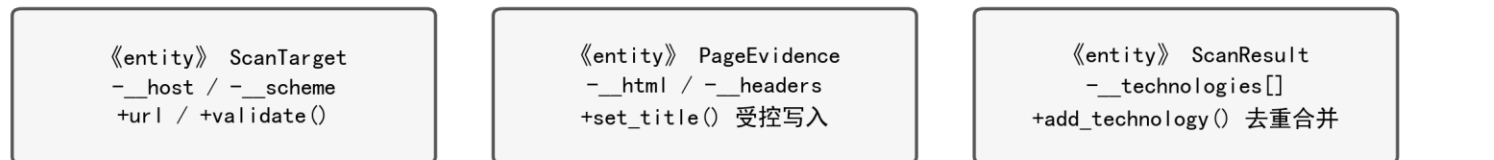
技术栈 Python 3.10 · Flask 3 · requests · BeautifulSoup4 · psycopg2 · PostgreSQL 18 · 零构建前端



核心类关系：四大特性的一张图

核心类关系图（封装 / 继承 / 多态 / 组合）

封装：实体类私有属性 + 只读 property



封装

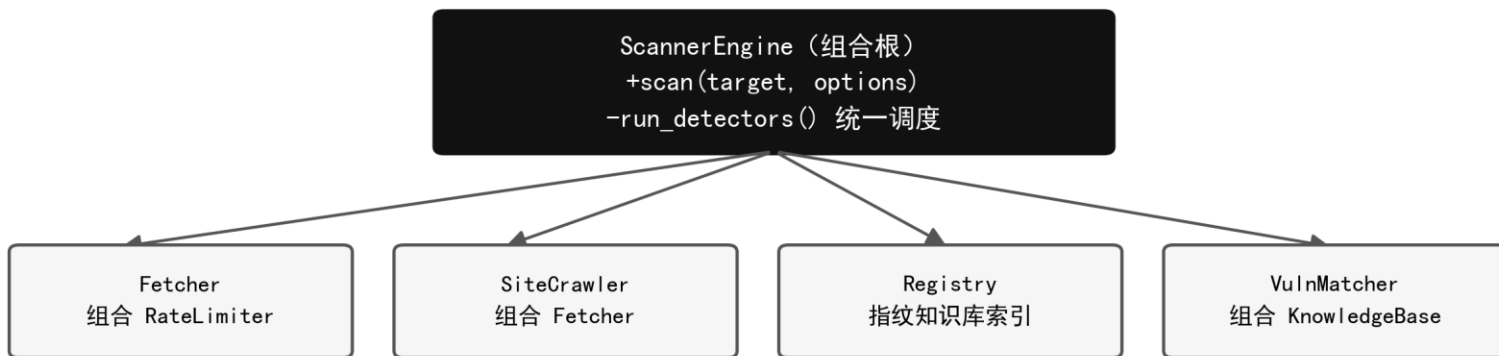
实体类私有属性 + 只读 property，仅两个受控写入点

继承

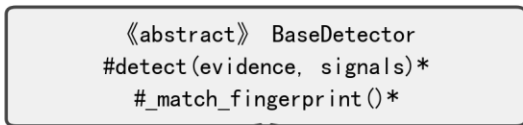
BaseDetector 抽象模板方法，7 个子类各消费一类证据

多态 + 组合

统一 detect() 接口；Engine 持有四大组件



组合：Engine 拥有 Fetcher / Crawler / Registry / VulnMatcher



继承 + 多态：7 个子类统一 detect() 接口，新增检测器零改引擎

数据库设计：九张表，知识库与结果分离

表名	用途	规模
categories	78 个检测类别字典	78 条
technologies	自建精编指纹（六类规则 JSONB）	370 条
tscan_fingerprints	社区表达式指纹（组内 AND、组间 OR）	2481 条
service_fp	nmap 风格端口服务指纹	11966 条
vuln_kb	漏洞情报（trgm 索引 + 版本区间 + 语义向量）	11024 条
cve_ms	微软安全公告索引	34931 行
kev	CISA 在野利用清单	1695 条
scans / scan_techs	扫描主表（JSONB）+ 技术明细（可检索）	随使用增长
jobs	异步任务队列	随使用增长

检索底座 product 字段 trgm 模糊索引（GIN）+ 256 维语义向量余弦重排；全部字面量 SQL + 参数绑定。

面向对象设计：四大特性的真实落点

封装

`models.py` 全部实体类

双下划线私有属性 + 只读 property
置信度随独立证据来源自动提升（受控写入）

继承

`BaseDetector` → 7 个子类

抽象模板方法 `detect()`
子类各消费一类证据：头/Cookie/meta/DOM/脚本/表达式/bundle

多态

`engine._run_detectors()`

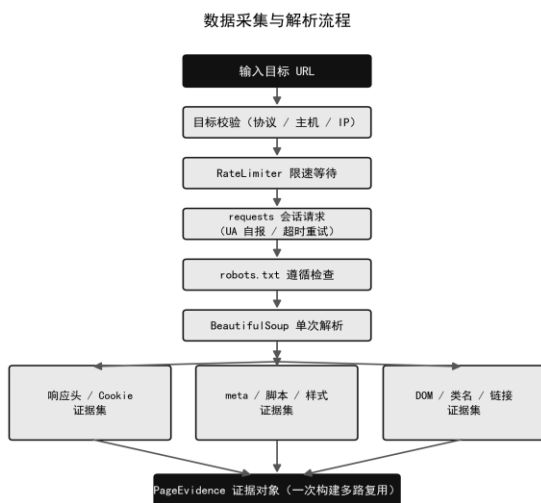
对检测器列表统一调用接口
新增检测器 = 新子类 + 注册一行，引擎零改动

组合

`ScannerEngine` 组合根

持有 `Fetcher/Crawler/Registry/VulnMatcher`
`Fetcher` 内组合 `RateLimiter` 限速器

爬虫技术：采集、解析与自我保护



01 requests.Session 统一采集

全局限速 0.4s · 超时重试 · UA 自报 SiteLens/1.0 ·
Cookie 会话注入支持认证扫描

02 BeautifulSoup 结构化解析

meta / script / DOM 选择器 / CSS 类名 / favicon
mmh3 哈希 → 结构化证据对象

03 同域 BFS 深度爬取

最多 4 页合并证据，先解析 robots.txt 遵循 Disallow，
子页面组件检出率显著提升

04 SSRF 防护 (工具自身安全)

协议白名单 + 主机黑名单 + DNS 解析逐 IP 校验，拒绝
内网/环回/保留地址与 DNS 重绑定

核心模块：被动指纹识别

2850+

产品指纹

78

检测类别

7

检测器（多态）

<1s

单页全量匹配

证据驱动 + 规则数据化：

370 条自建精编指纹（JSONB 六类规则）+ 2481 条社区表达式指纹（组内 AND、组间 OR、!= 取反，导入期预解析）

多来源独立命中自动合并，置信度每来源 +5（上限 100）；版本号从响应头 / generator / 脚本文件名正则捕获

BundleDetector 补齐「打包进产物就消失」的框架：React / Vue / Framer Motion 等 15 种库签名

核心模块：验证型检测引擎

MoE 式模板三路调度

① tag 硬匹配置顶

识别出 WordPress → WP 专项模板优先

② 语义向量路由

TF-IDF 哈希向量余弦排序（内容寻址）

③ 轮转游标兜底

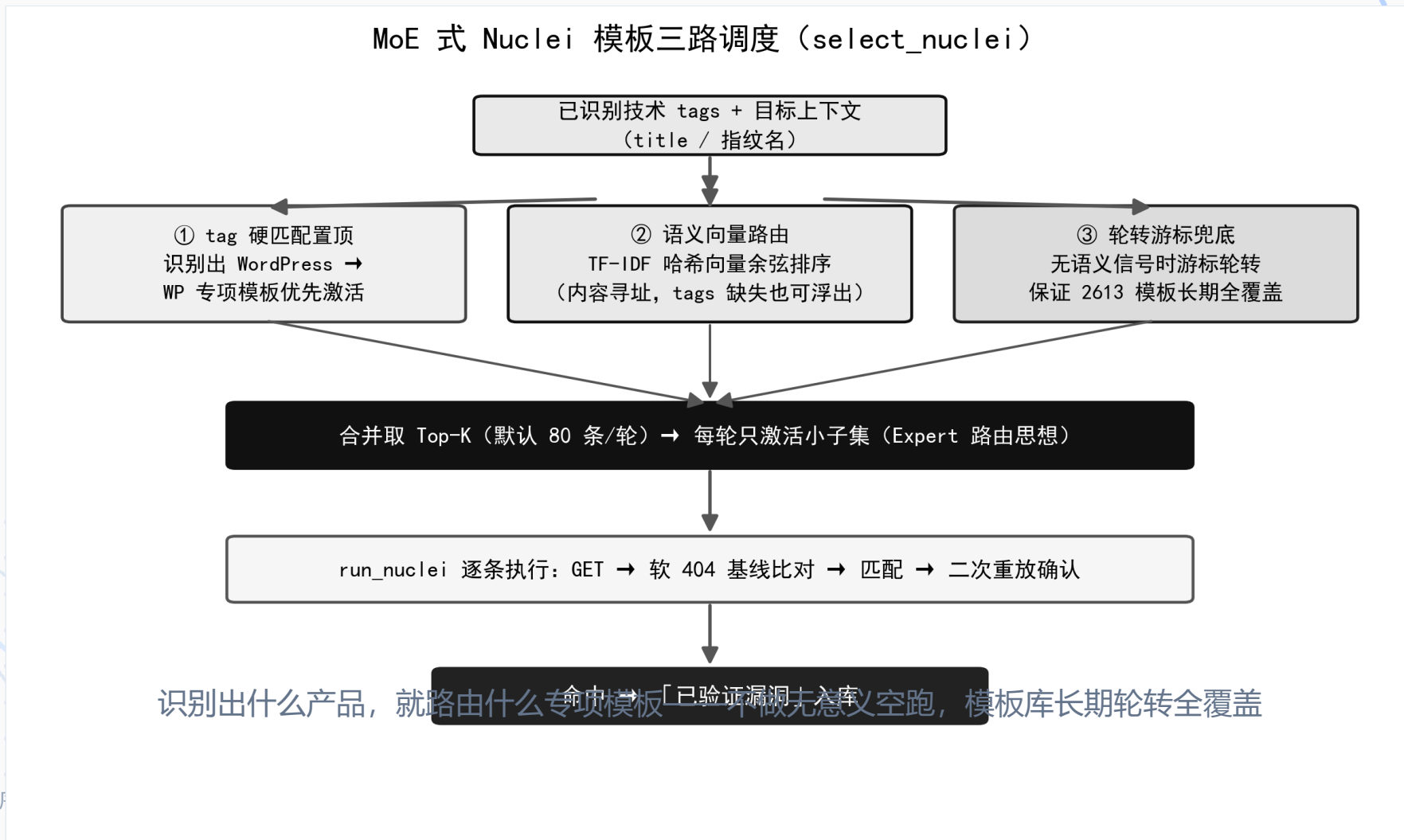
无信号时轮转，2613 模板长期全覆盖

每轮仅激活 80 条模板 → 不做无差别空跑

结论可信度设计

- ▶ 只读无害：42 条自研 check 全部只读（.git 泄露 / 备份文件 / Actuator 暴露 / 目录列表...）
- ▶ 软 404 基线：先请求随机不存在路径，与基线相同的响应直接跳过
- ▶ 二次确认：命中后立即重放，两次均命中才采信，排除 CDN 抖动假阳性
- ▶ 附带轻量 DAST：反射 XSS 标记回显 / 报错型 SQLi / 开放重定向 / 目录遍历

MoE 式调度：让 2613 条模板各得其所



核心模块：漏洞情报三级判定

确认受影响

版本号落在 OSV 受影响区间

例: Next.js 13.5.1 → CVE-2025-29927

可能受影响

同名组件但无版本号，仅提示

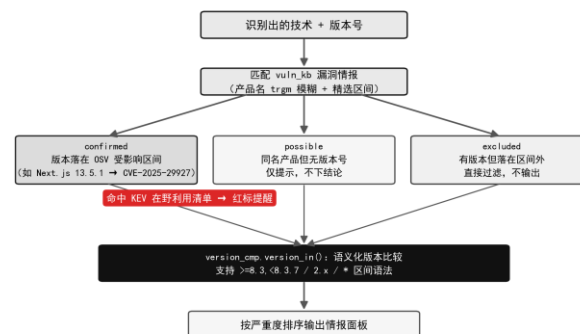
不下结论，供人工跟进

不受影响

有版本但落在区间外

直接过滤不输出，抑制误报

漏洞情报三级判定流程 (VulnMatcher.match)



数据底座：11024 条漏洞情报 · 1323 条 OSV 版本区间 · 1695 条 CISA KEV 在野利用（命中红标） · 34931 行微软公告，24h 守护线程自动更新

语义化版本比较：支持 $\geq 8.3, < 8.3.7 / 2.x / *$ 全部区间形态；检索 = trgm 粗筛 + 向量余弦重排（亚秒级）

网络层检测：传输层与域名体系

检测项	判定条件	级别
证书过期	notAfter 早于当前时间	高危
证书临期	notAfter 距今不足 30 天	提醒
自签名证书	颁发者与主体相同且非受信 CA	高危
弱协议协商	可完成 SSLv3 / TLS1.0 握手	中危
邮件伪造风险	缺少 SPF/DMARC 或 p=none	中危
端口服务识别	6 常见端口 banner + 最小 HTTP 探测	只读

轻触原则

- 每端口至多两次交互
- 先静默读 banner，无响应才发最小探测
- 子域名结果归位到组织主域评估
- 默认关闭，显式开启

11966 条 nmap 风格服务指纹用于端口识别；nslookup 输出按 GBK 逐段解析（已修复中文系统编码缺陷）。

源码审计：16 规则扫描 + 污点数据流

污点分析数据流模型

SOURCES 不可信入口: input / request.args
/ request.form / cookies / sys.argv

SINKS 危险落点: 执行类 / 反序列化类
/ 文件写入类

判定: source → 赋值/拼接 → sink

即报告「污点数据流入危险函数」

工程细节

- ▶ AST 级同函数赋值链追踪, 比单行正则更接近真实数据流
- ▶ 16 条危险规则覆盖执行 / 反序列化 / 文件读取
- ▶ 支持源码文件与 zip 压缩包, tempfile 审计后即删
- ▶ 纯本地解析, 代码不出机器

登录爆破：授权专属模块

机制设计

- ▶ 宽容表单解析：兼容无 form 标签 / 字段无 name / 中文 placeholder
- ▶ 失败基线 + 响应差异判定命中，命中即停
- ▶ 每次尝试重载登录页刷新验证码
- ▶ 总请求数硬性封顶 300 次

验证码分级（本地 OCR）

数字 / 算式

OCR + 四则运算求值

点选式

检测框坐标定位

滑块式

缺口偏移量（如实标注边界）

授权门禁：未勾选书面授权声明，模块无法启动

Web 工作台：每个功能都有页面承载

首页 / 输入直达扫描

扫描工作台 /app 等级 / 会话 / 实时面板

源码审计 /audit 拖拽上传审计

批量扫描 /batch 50 站点队列

扫描历史 /history 详情 + diff + 导出

情报库 /intel 模糊 + 语义检索

API 文档 /api-docs 14 组接口

产品介绍 /about 能力总览与署名

导出四格式 JSON（全量归档）· 明细 CSV · 78 列宽表 CSV（资产台账）· 单文件 HTML 报告（离线交付）；Token 鉴权的 REST API 可脚本集成。

与同类工具的关系：串成流水线，而非重复造轮

维度	SiteLens	Nuclei	Wappalyzer	商业扫描器
技术指纹	2850 产品 · 78 类别	无	3000+ 技术	有
漏洞验证	模板路由 + 无害检测	7000+ 模板	无	完整
漏洞情报	三级判定 + KEV	无	无	部分
网络层检测	TLS / SPF / 端口	无	无	完整
源码审计	规则 + 污点分析	无	无	无
数据归属	本地 PostgreSQL	-	云服务	云 / 授权码
价格	免费	免费	付费	\$\$\$

定位：验证环节与 Nuclei 生态兼容（2613 条模板），差异化在指纹、情报与资产沉淀——站在巨人肩上，而非重复造轮。

系统测试：三层验证体系

49

项单元 / 集成测试

unittest 离线可重复

32

项 API 冒烟测试

页面 / 参数 / 边界 / 导出

14

项真实站点识别

演示站点全面识别

4

项靶场回归

命中 100% · 干净站零误报

测试发现并修复的真实问题：

扫描级扩展信息被子模块覆盖 → 报告缺项 · 嵌于 Next.js 流式载荷中的内联组件漏检（补 body 正则指纹） · 中文 Windows nslookup 编码不一致 → 邮件安全误报

安全工具的纪律：合规内建于代码

SSRF 防护

DNS 解析后逐 IP 校验

扫描器自身不会被当成访问内网的跳板

礼貌访问

0.4s 限速 · UA 自报 · robots 遵循

对目标的压力可控、行为可识别

POC 不落盘

导入期即丢弃 rules / payload

只做情报关联，不执行攻击载荷

授权门禁

登录爆破独立模块 + 授权声明

高危能力默认关、显式确认才可用

站在开源社区的肩膀上（数据来源署名）

Nuclei Templates

2613 条验证模板 [MIT](#)

TscanPlus 指纹库

2481 条表达式指纹 [社区开源](#)

OSV.dev

1188+ 条版本区间 [Apache-2.0](#)

CISA KEV

1695 条在野利用 [官方](#) [JSON](#)

afrog / xray

POC 元数据（载荷不执行） [开源](#)

微软安全公告

22133 个 CVE 索引 [公开数据](#)

所有数据来源均在报告与系统内署名；GB7714 参考文献清单见实训报告第 41 页。

总结与展望

做到了

- ▶ 面向对象结构清晰：三次能力升级引擎零改动
- ▶ 「指纹 → 验证 → 情报」全链路完整，三级判定控制误报
- ▶ 工程化程度高：异步任务 / 批量 / diff / 四格式导出 / Token API
- ▶ 真实可用：数据全在本地 PG，非演示玩具

不足与改进

- ▶ 吞吐量与 Go 系引擎有量级差距 → 模板请求按 path 聚类提速
- ▶ requests 栈检不出需浏览器渲染的组件 → 明确的能力边界
- ▶ 无 OOB 回连，盲注类检不出 → 计划自托管轻量回调服务
- ▶ 验证引擎计划增加 extractor，抽取版本回灌情报判定

恳请各位老师批评指正

现场演示环节：扫描工作台 · 指纹识别 · 已验证漏洞 · 情报三级判定 · 源码审计

sitelens · 信息工程学院 · 信息安全 2025 级 (25 信安 1 班) · 组长 王振宇